

PINIT-DNA

Smart Links Engine — Code Audit Report

A feature-by-feature evidence-based review of the Smart Links (secure document sharing) implementation — generation, tracking, secure viewer, audit trail, and gap analysis.

Prepared for	Ashwitha Kavvam — PINIT-DNA Project
Audit date	2026-06-08
Scope	Smart Links Engine (15-section checklist, 100+ items)
Method	Direct codebase inspection (grep / file reads) — no assumptions
Overall completion	≈ 38–42% (core share→track→timeline loop fully working)

● DONE ● PARTIAL ● MISSING

1. Smart Link Generation

Feature	Status	Evidence
Secure link generation	DONE	share-link.service.ts — crypto.randomBytes(8) → base64url token, uniqueness checked vs DB
JWT token generation	MISSING	jsonwebtoken is in package.json but never imported/used in share code — opaque random tokens used instead
HMAC signature	MISSING	No crypto.createHmac anywhere in src/services/share/
Session nonce	PARTIAL	Client-generated sessionId (sessionStorage) groups events — not a cryptographic nonce
Link expiration	DONE	expiresAt field; expiresIn (hrs) → computed date; isExpired check in getPublicInfo()
One-time access links	MISSING	Only generic maxViews counter — no single-use flag
Link revocation	DONE	ShareLinkService.revoke() sets isActive=false; DELETE /api/v1/share/:token wired
Download limits	PARTIAL	allowDownload is boolean on/off — no numeric 'max N downloads'
View-only mode	DONE	When allowDownload=false, Download button hidden; file streamed inline only

Files: share-link.service.ts, share-link.controller.ts, share.routes.ts

Endpoints: POST /api/v1/share, DELETE /api/v1/share/:token

Database: share_links table

2. Access Policies

Feature	Status	Evidence
Access policy builder	PARTIAL	ShareModal in VaultPage.tsx — basic form (expiry/views/download/name/note), not a generalized builder
Expiry policies	DONE	Presets: 1h / 24h / 7 days / 30 days / never
Device restrictions	MISSING	Device type only recorded, never enforced
Geo restrictions	MISSING	Country/city only logged, never used to allow/deny
Email verification	MISSING	No email field/flow in share code
OTP verification	MISSING	Zero matches in codebase
MFA escalation	MISSING	Not implemented
User-bound access	MISSING	requireName captures free-text name only — not an authenticated identity

Files: client/src/pages/VaultPage.tsx (ShareModal)

3. Secure Viewer

Feature	Status	Evidence
Protected viewer	DONE	ShareViewerPage.tsx — public route <code>/s/:token</code> , gated by name/expiry/exhaustion screens
Watermark overlay	DONE	Repeating diagonal 'PINIT-DNA · token · name' overlay, pointer-events-none
Right-click disable	DONE	<code>onContextMenu={e => e.preventDefault()}</code> on page wrapper
Print disable	MISSING	Only DETECTS print attempts (beforeprint + matchMedia) — content not hidden from print
Download disable	DONE	Download button conditionally rendered only if <code>allowDownload=true</code>
Blur on inactivity	MISSING	No idle-blur logic anywhere
Tab-switch detection	DONE	<code>visibilitychange</code> listener → <code>track('TAB_SWITCH')</code>
Session timeout	MISSING	No timeout beyond the link's own expiresAt

Files: `client/src/pages/ShareViewerPage.tsx`

4. Audit Trail

Feature	Status	Evidence
File open logging	DONE	<code>track('VIEWED')</code> on load → <code>ShareAccessLog</code> row + <code>viewCount</code> increment
Download logging	DONE	<code>handleDownload()</code> → <code>track('DOWNLOADED')</code>
Share logging	DONE	<code>SHARE_CREATED</code> event synthesized in <code>TimelinePage.buildHistory()</code> from <code>ShareLink.createdAt</code>
Scroll depth tracking	DONE	<code>onScroll</code> computes %, fires <code>SCROLL</code> at 25/50/75/100% milestones
Session duration	MISSING	<code>sessionId</code> groups events but duration never computed/displayed
Access history	DONE	<code>GET /api/v1/share/:token/logs</code> → full <code>accessLogs</code> list per link
Audit export	MISSING	No CSV/PDF export specific to share access logs

Files: `share-link.service.ts` (`recordAccess/getTimelineEvents`), `TimelinePage.tsx`

Endpoints: `GET /api/v1/share/:token/logs`, `GET /api/v1/share/timeline/:dnald`

Database: `share_access_logs` table

5. Device Fingerprinting

Feature	Status	Evidence
Browser detection	DONE	parseUserAgent() regex-classifies Chrome/Firefox/Edge/Safari/Opera
OS detection	DONE	Same function → Windows/macOS/Linux/Android/iOS
Device fingerprint (canvas/WebGL hash)	MISSING	Only coarse UA parsing — no canvas/audio/WebGL fingerprint hash
Screen resolution	MISSING	screen.width/height never read or sent
Timezone capture	DONE	Intl.DateTimeFormat().resolvedOptions().timeZone sent + stored
VPN detection	MISSING	Not implemented
Tor detection	MISSING	Not implemented

Files: share-link.service.ts (parseUserAgent)

6. Geo Intelligence

Feature	Status	Evidence
IP capture	DONE	X-Forwarded-For honored for ngrok; app.set('trust proxy', true) in app.ts
Country detection	DONE	geoFromIp() → ip-api.com → stored as country
Region detection	PARTIAL	region/isp fetched by geoFromIp() but NOT persisted — schema lacks region/isp columns
Geo analytics	MISSING	Raw country/city shown per-event only — no aggregation/dashboard
Geo heatmaps	MISSING	Not implemented

Files: share-link.service.ts (geoFromIp), TimelinePage.tsx

7. Behavior Tracking

Feature	Status	Evidence
Mouse tracking	MISSING	No mousemove/click heatmap logic
Scroll tracking	DONE	See Section 4 — 25/50/75/100% milestone events
Reading speed	MISSING	Not computed
Interaction frequency	MISSING	Not computed
Idle detection	MISSING	Not implemented

Feature	Status	Evidence
Re-access attempts	PARTIAL	viewCount + BLOCKED_MAX_VIEWS/BLOCKED_EXPIRED logged — no dedicated repeat-visitor analysis

Files: ShareViewerPage.tsx, share-link.controller.ts

8. Screenshot Protection

Feature	Status	Evidence
Screenshot attempt detection	DONE	keydown/keyup detect PrintScreen, Win+Shift+S, Cmd+Shift+3/4/5, F12, Ctrl+Shift+I → SCREENSHOT_ATTEMPT (hardened with keyup fallback + cooldowns)
Screen recording detection	MISSING	Not possible via standard browser APIs — not implemented
Watermark escalation	MISSING	Watermark is static; no dynamic response to suspicious events
Security event logging	DONE	COPY_ATTEMPT / SCREENSHOT_ATTEMPT / PRINT_ATTEMPT / TAB_SWITCH persisted + shown in Timeline with red/amber badges

Files: ShareViewerPage.tsx, TimelinePage.tsx

9. AI Risk Engine

Entire section not built. The raw signal needed to power this (logged copy/screenshot/print/geo/device events) already exists — this is the highest-leverage next step.

Feature	Status	Evidence
Risk scoring	MISSING	Zero matches for riskScore/RiskEngine/riskLevel in codebase
Device risk analysis	MISSING	Not implemented
Geo risk analysis	MISSING	Not implemented
Behavioral risk analysis	MISSING	Not implemented
Suspicious activity detection (automated)	MISSING	Events are logged but nothing scores/reacts to them
Automated response engine	MISSING	Not implemented (e.g., no auto-revoke on threat)

10. Session Monitoring

Entire section missing. 'sessionId' exists only as a client-generated grouping key for log rows — there is no live session registry, concurrency check, or remote kill-switch.

Feature	Status	Evidence
Live sessions	MISSING	No live session registry
Concurrent session detection	MISSING	Not implemented
Session intelligence	MISSING	Not implemented
Session revocation	MISSING	Not implemented
Force logout	MISSING	Not implemented

11. Admin Dashboard

Feature	Status	Evidence
Live session monitor	MISSING	Not implemented
Threat dashboard	MISSING	Not implemented
Risk center	MISSING	Not implemented
Geo analytics	MISSING	Not implemented (raw geo strings only)
Access control center	PARTIAL	VaultPage ShareModal + listShareLinks is closest — view/revoke links, not a unified control center
Audit dashboard	DONE	File Timeline (TimelinePage.tsx) doubles as the audit view — full share lifecycle + access events per file

Files: VaultPage.tsx, TimelinePage.tsx

12. Storage Security

Note: encryption is inherited from the existing Vault subsystem — Smart Links add no new encryption; they stream the already-encrypted/decrypted file via `vaultService.retrieve()`.

Feature	Status	Evidence
AES-256 encryption	DONE	Vault shows AES-256-GCM; <code>vaultService.retrieve()</code> decrypts for <code>serveSharedFile</code> (existing Vault subsystem, reused)
Per-file encryption keys	PARTIAL	Depends on pre-existing Vault implementation — not verified in this Smart Links audit pass
Key versioning	MISSING	Not found in reviewed share/vault code
Backup storage	PARTIAL	<code>vault-backup.service.ts</code> exists (pre-existing Vault feature, unrelated to Smart Links specifically)
Immutable storage	MISSING	Not implemented
Regional storage policy	MISSING	Not implemented

13. Access Control Matrix

The only real access-control levers today are: link expiry, max views, name-gate, and download toggle.

Feature	Status	Evidence
RBAC	MISSING	Zero matches for RBAC/hasPermission
ABAC	MISSING	Not implemented
Time-limited access	DONE	expiresAt — see Section 1
Device restrictions	MISSING	Not enforced
Geo restrictions	MISSING	Not enforced
IP restrictions	MISSING	Not implemented

14. Technology Stack Verification

Technology	Status	Evidence
AWS S3 / MinIO	MISSING	No aws-sdk / @aws-sdk / minio in package.json — files live in the existing local/Postgres-backed Vault
KMS / HashiCorp Vault	MISSING	Not present
Auth0 / Keycloak	MISSING	Not present
OPA Policy Engine	MISSING	Not present
ELK Stack	MISSING	Not present — logging uses the app's own logger into Postgres tables, not Elasticsearch/Logstash/Kibana

15. Final Gap Analysis

1. What is fully completed

- Link generation: random secure tokens, expiry, max-views, revoke
- Access logging pipeline (VIEWED, DOWNLOADED, BLOCKED_*, COPY/SCREENSHOT/PRINT/SCROLL/TAB_SWITCH)
- IP capture + geolocation (country/city) via ip-api.com
- Browser/OS/device parsing from User-Agent
- Secure viewer: watermark, right-click block, name gate, download gate, view-limit/expiry screens
- Full File Timeline integration showing the entire share lifecycle
- Behavioral tracking: scroll depth + copy/screenshot/print/tab-switch detection (hardened this session)

2. What is partially completed

- 'Access policies' — only expiry/max-views/name/download toggle exist; no real policy builder or device/geo/IP enforcement
- Geo intelligence — captured but not surfaced as analytics/heatmaps; region/isp fetched but not persisted
- Download limits — boolean only, not a numeric cap
- Re-access tracking — logged as block events, not analyzed further

3. What is UI-only (no real backend enforcement)

- 'View-only mode' / download disable — purely hides the UI button; file-serving endpoint doesn't differentiate
- Print 'disable' — only detection exists; content isn't actually hidden from printing

4. What is backend-only (no dedicated UI)

- getShareLinkLogs (full per-link logs endpoint) — exposed via API but no dedicated admin screen beyond the Timeline
- geoFromIp region/isp data — fetched server-side, dropped before reaching the UI

5. What is completely missing

- JWT/HMAC-signed links, OTP/email verification, MFA
- Device fingerprinting (canvas/WebGL), VPN/Tor detection, screen resolution capture
- AI Risk Engine (entire section — scoring, automated response)
- Session Monitoring (entire section — live sessions, concurrency, force logout)
- Admin Threat/Risk/Geo dashboards
- RBAC/ABAC and geo/device/IP access restrictions
- Audit export
- Enterprise infrastructure: S3/MinIO, KMS/Vault, Auth0/Keycloak, OPA, ELK

6. What can be demonstrated TODAY

- Generate a share link from Vault Explorer with expiry / view-limit / download / name-gate options
- Open the link → see watermark, name gate, view-limit/expiry blocking screens

- Watch the File Timeline populate live: link created → copied → viewed (real IP, country, city, browser, OS) → scroll milestones → copy/screenshot/print attempts flagged in red/amber → view-limit exhaustion blocking access
- Revoke a link and show it instantly stops working

7. What still needs development (priority order)

- 1. Real per-link policies: device/geo/IP allow-deny lists, numeric download caps, one-time-use links
- 2. Risk scoring engine consuming the already-logged events — highest leverage, raw signal already captured
- 3. Admin dashboard tying together live sessions, threat view, geo analytics
- 4. Stronger identity gates: OTP/email verification before any MFA-level claims are credible
- 5. True content-level print/copy prevention (not just detection)
- 6. Session lifecycle (live session registry + force-logout) if 'session monitoring' is a hard requirement

Overall completion estimate: $\approx$ 38–42% against the full 15-section / 100+ item spec.

Sections fully delivered: Link Generation (mostly), Secure Viewer (mostly), Audit Trail (mostly), Geo capture, Screenshot detection — i.e. the entire 'share → track → timeline' loop demoed working end-to-end. Sections at 0%: AI Risk Engine, Session Monitoring, most of the Access Control Matrix, and the enterprise infrastructure stack (S3/KMS/Auth0/OPA/ELK) — these are advanced enterprise add-ons beyond the original 'share it and track everything in the Timeline' request.

Bottom line: the core promise — generate a share link, send it, and see everything tracked in the File Timeline (created, copied, opened, who, where, what they tried to do) — is **DONE and demoable**. What remains is the enterprise security layer (risk scoring, session intelligence, policy engine, infra integrations).